

# Chapter 17 Security

After studying this chapter, the student should be able to:

- Define three security goals – *confidentiality*, *integrity* and *availability* – as well as attacks that threatens these security goals.
- Define five security services – *data confidentiality*, *data integrity*, *authentication*, *nonrepudiation* and *access control* – to prevent security attacks.
- Discuss two techniques for providing security services: *cryptography* and *steganography*.
- Distinguish between *symmetry-key cryptography* and *asymmetric-key cryptography* and show how confidentiality can be provided using *either symmetric-key* or *asymmetric-key ciphers*.
- Show how integrity can be provided using *cryptographic hashing functions*.
- Discuss the idea of *digital signatures* and how they can be provided message integrity, message authentication and nonrepudiation.
- Brief discuss entity authentication and categories of witnesses: something known, something possessed and something inherent.
- Discuss four techniques used for entity authentication: *password-based*, *challenge-response*, *zero knowledge* and *biometrics*.
- Discuss key management in symmetric-key and asymmetric-key cryptography.

# 17.1 INTRODUCTION

- We are living in the information age. We need to keep information about every aspect of our lives. In other words, information is an asset that has a value like any other asset. As an asset, information needs to be secured from attacks. To be secured, information needs to be hidden from unauthorized access (***confidentiality***), protected from unauthorized change (***integrity***), and available to an authorized entity when it is needed (***availability***).
- During the last three decades, computer networks have created a revolution in the use of information. Information is now distributed. Authorized people can send and retrieve information from a distance using computer networks. Although the three above-mentioned requirements changed, they now have some new dimensions. Not only should information be confidential when it is stored; there should also be a way to maintain its confidentiality when it is transmitted from one computer to another.

## 17.1.1 Security goals

We will first discuss three security goals: **confidentiality**, **integrity**, and **availability**.

### Confidentiality 機密性

- Confidentiality, keeping information secret from unauthorized access, is probably the most common aspect of information security: we need to protect confidential information. An organization needs to guard against those malicious actions that endanger the confidentiality of its information.

### Integrity 完整性

- Information needs to be changed constantly. In a bank, when a customer deposits or withdraws money, the balance of their account needs to be changed. Integrity means that changes should be done only by authorized users and through authorized mechanisms.

### Availability 可用性

- The information created and stored by an organization needs to be available to authorized users and applications. Information is useless if it is not available. Information needs to be changed constantly, which means that it must be accessible to those authorized to access it. Unavailability of information is just as harmful to an organization as a lack of confidentiality or integrity. Imagine what would happen to a bank if the customers could not access their accounts for transactions.

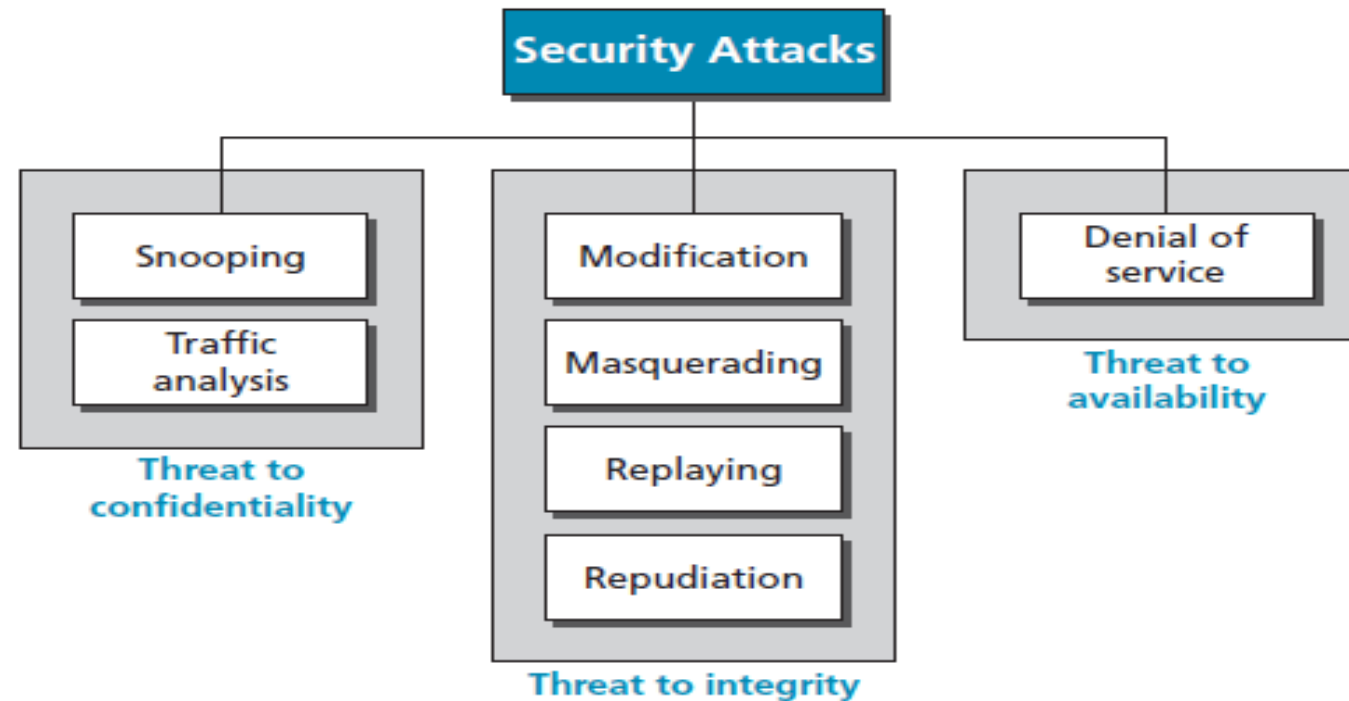
Figure 17.1 Taxonomy of security goals



## 17.1.2 Attacks

- The three goals of security—confidentiality, integrity, and availability—can be threatened by security attacks.
- Figure 17.2 relates the taxonomy of attack types to security goals.

**Figure 17.2** *Taxonomy of attacks with relation to security goals*



## Attacks threatening confidentiality

- In general, two types of attack threaten the confidentiality of information: ***snooping*** and ***traffic analysis***. Snooping refers to unauthorized access to or interception of data. Traffic analysis refers other types of information collected by an intruder by monitoring online traffic.

## Attacks threatening integrity

- The integrity of data can be threatened by several kinds of attack: ***modification***, ***masquerading***, ***replaying***, and ***repudiation***.

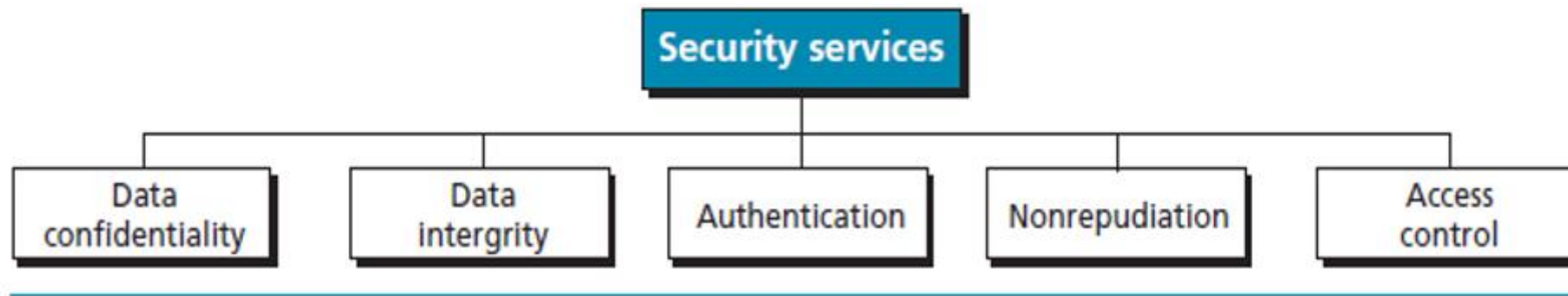
## Attacks threatening availability

- We mention only one attack threatening availability: ***denial of service***.

# Security Services and Techniques

- ITU-T defines some security services to achieve security goals and prevent attacks.
- Each of these services is designed to prevent one or more attacks while maintaining security goals.
- The actual implementation of security goals needs some techniques.
- Two techniques are prevalent today: one is very general (***cryptography***) and one is specific (***steganography***).

Figure 17.3 Security services



# Cryptography

- Some security services can be implemented using cryptography. Cryptography, a word with Greek origins, means “secret writing”. However, we use the term to refer to the science and art of transforming messages to make them secure and immune to attacks. Although in the past cryptography referred only to the encryption and decryption of messages using secret keys, today it is defined as involving three distinct mechanisms: **symmetric-key encipherment**, **asymmetric-key encipherment**, and **hashing**.

# Steganography

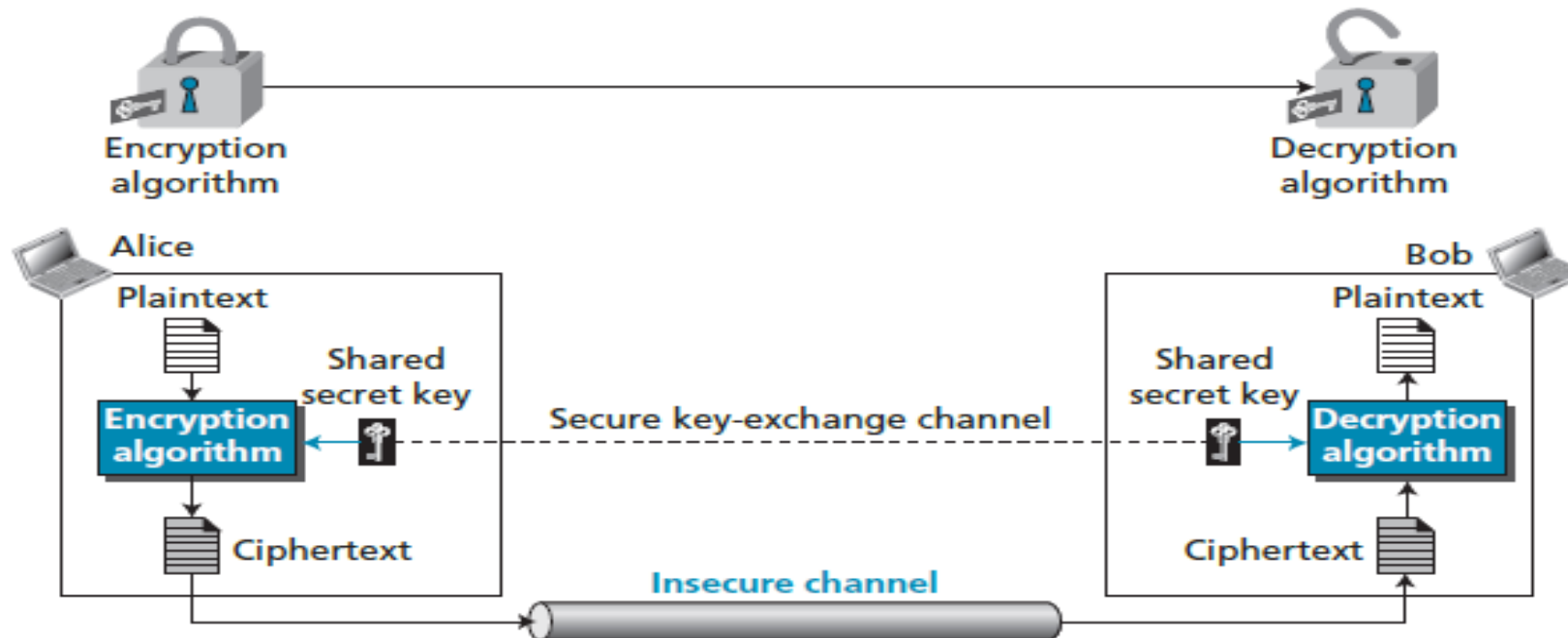
- Another technique that was used for secret communication in the past is being revived at the present time: steganography. The word **steganography**, with origins in Greek, means ‘covered writing’, in contrast with cryptography, which means ‘secret writing’.

Cryptography means concealing the contents of a message by enciphering; steganography means concealing the message itself by covering it with something else.

# Symmetric-key Ciphers

- A symmetric-key cipher uses the same key for both encryption and decryption, and the key can be used for bidirectional communication, which is why it is called *symmetric*.
- Figure 17.4 shows the general idea behind a symmetric-key cipher.

**Figure 17.4** *The general idea of symmetric-key cryptography*





- Note that the symmetric-key encipherment uses a single key (the key itself may be a set of values) for both encryption and decryption.
- In addition, the encryption and decryption algorithms are inverses of each other.
- If  $P$  is the plaintext,  $C$  is the ciphertext, and  $K$  is the key
  - the encryption algorithm  $EK(P)$  creates the ciphertext from the plaintext;
  - the decryption algorithm  $DK(C)$  creates the plaintext from the ciphertext.
- We assume that  $EK(x)$  and  $DK(x)$  are inverses of each other: they cancel the effect of each other if they are applied one after the other on the same input.
- Encryption can be thought of as locking the message in a box; decryption can be thought of as unlocking the box. In symmetric-key encipherment, the same key locks and unlocks as shown in Figure 17.4.

# Traditional symmetric-key ciphers

- Traditional ciphers belong to the past. However, we briefly discuss them here because they can be thought of as the components of the modern ciphers. To be more exact, we can divide traditional ciphers into ***substitution ciphers*** and ***transposition ciphers***.

A **substitution cipher** replaces one symbol with another.

**Example 17.1** Use the additive cipher with **key = 15** to encrypt the message “hello”.

**Solution** We apply the encryption algorithm to the plaintext, character by character:



|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |
|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|
| a | b | c | d | e | f | g | h | i | j | k | l | m | n | o | p | q | r | s | t | u | v | w | x | y | z |
| p | q | r | s | t | u | v | w | x | y | z | a | b | c | d | e | f | g | h | i | j | k | l | m | n | o |

The ciphertext is therefore “**wtaad**”.

# A transposition cipher reorders (transposes) the symbols.

## Example 17.2

Alice needs to send the message 'Enemy attacks tonight' to Bob. Alice and Bob have agreed to divide the text into groups of five characters and then permute the characters in each group. The following shows the grouping after adding a bogus character (z) at the end to make the last group the same size as the others.

e n e m y   a t t a c   k s t o n   i g h t z

The key used for encryption and decryption is a permutation key, which shows how the characters are permuted. For this message, assume that Alice and Bob used the following key:

|            |   |   |   |   |   |   |   |            |
|------------|---|---|---|---|---|---|---|------------|
| Encryption | ↓ | 3 | 1 | 4 | 5 | 2 | ↑ | Decryption |
|            |   | 1 | 2 | 3 | 4 | 5 |   |            |

The third character in the plaintext block becomes the first character in the ciphertext block, the first character in the plaintext block becomes the second character in the ciphertext block, and so on. The permutation yields:

e e m y n   t a a c t   t k o n s   h i t z g

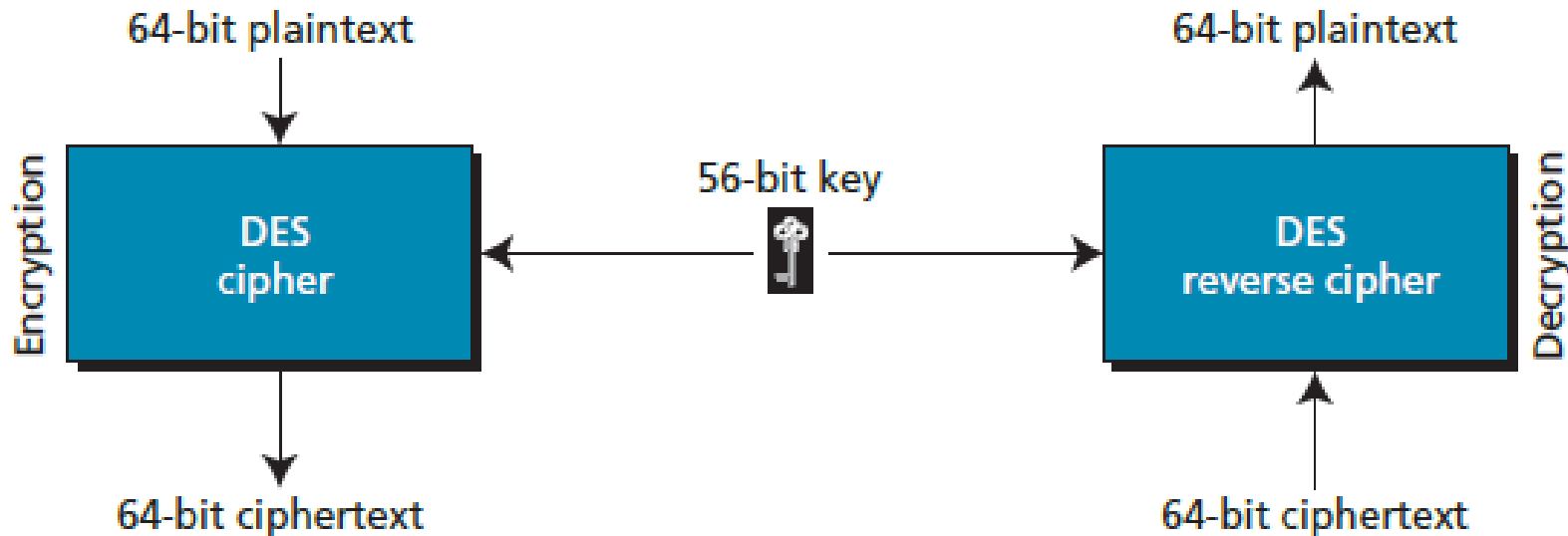
Alice sends the ciphertext 'eemyntaacttkonshitzg' to Bob. Bob divides the ciphertext into five-character groups and, using the key in the reverse order, finds the plaintext.

# Modern symmetric-key ciphers: DES and AES

## DES

- The Data Encryption Standard (DES) is a symmetric-key block cipher published by the US National Institute of Standards and Technology (NIST) in 1977.
- DES has been the most widely symmetric-key block cipher since its publication.

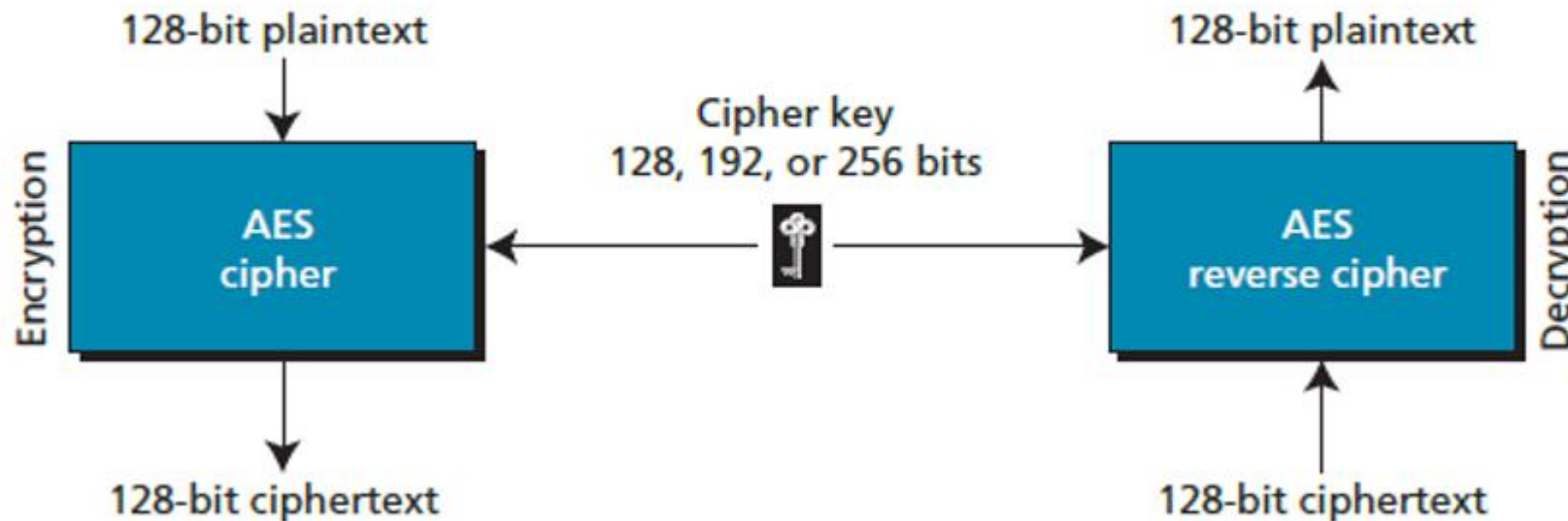
**Figure 17.5** *Encryption and decryption with DES*



# AES

- The Advanced Encryption Standard (AES) is a symmetric-key block cipher published by the US National Institute of Standards and Technology (NIST) in 2001 in response to the shortcoming of DES, for example its small key size.
- In 1997 the NIST started looking for a replacement for DES. The NIST specifications required a block size of 128 bits and three different key sizes, of 128, 192, and 256 bits.

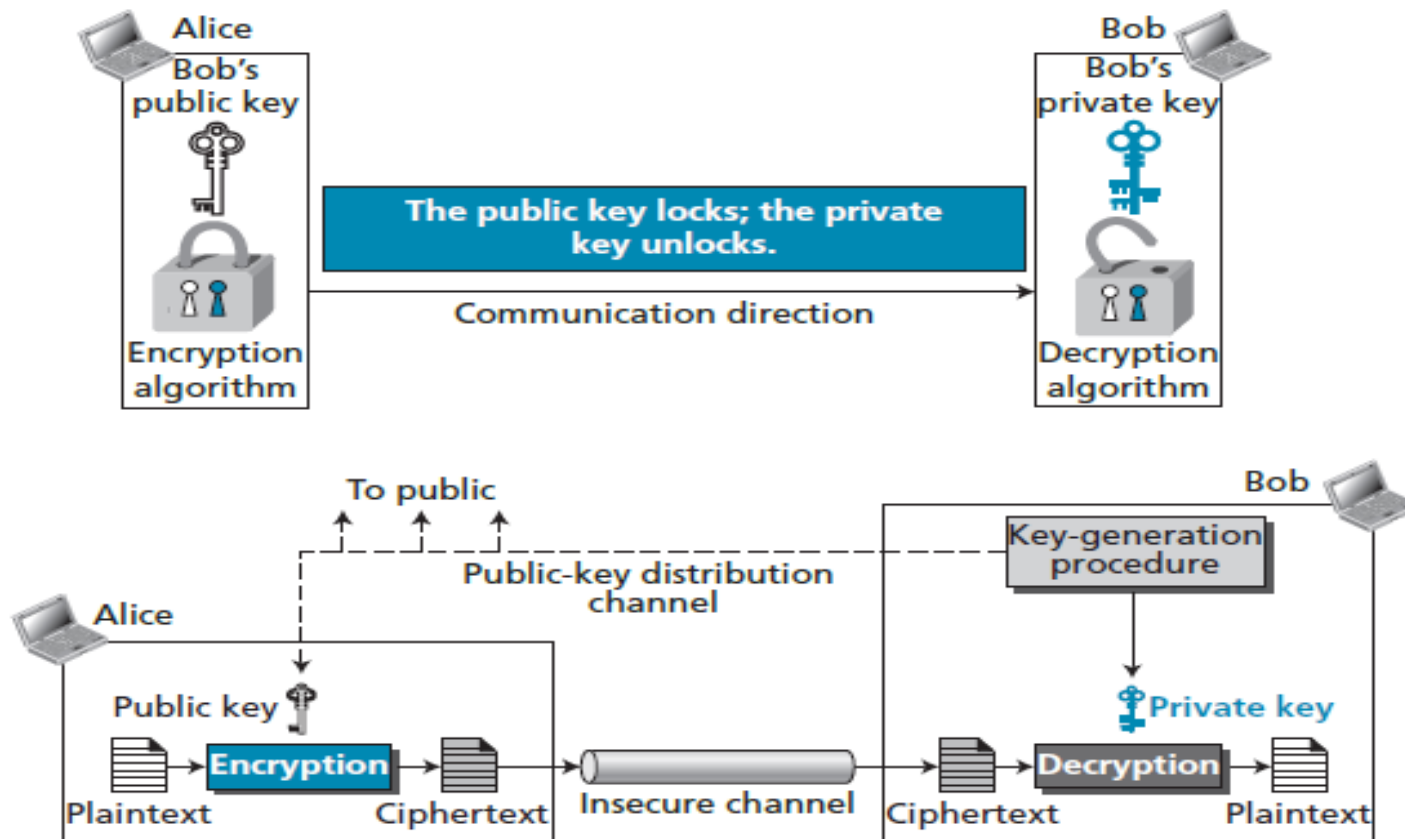
**Figure 17.6** *The general design of the AES encryption cipher*



# Asymmetric-key cryptography

- In symmetric-key cryptography, there are two distinctive keys: a ***private key*** and a ***public key***.

Figure 17.7 The general idea behind asymmetric-key cryptography



# RSA cryptosystem

- The common public-key algorithm is the RSA cryptosystem, named for its inventors (Rivest, Shamir, and Adleman).
- RSA uses two exponents,  $e$  and  $d$ , where  $e$  is public and  $d$  is private.
- Suppose  $\mathbf{P}$  is the plaintext and  $\mathbf{C}$  is the ciphertext.
- Alice uses  $\mathbf{C} = \mathbf{P}^e \bmod n$  to create ciphertext  $\mathbf{C}$  from plaintext  $\mathbf{P}$ .
- Bob uses  $\mathbf{P} = \mathbf{C}^d \bmod n$  to retrieve the plaintext sent by Alice.
- The modulus  $n$ , a very large number, is created during the key generation process.

## 17.3 COMPARISON OF METHODS

- Symmetric-key and asymmetric-key cryptography will continue to exist in parallel as they are complements of each other; the advantages of one compensate for the advantages of the other.
  - In symmetric-key cryptography, the plaintext and ciphertext are thought of as a combination of symbols. Encryption and decryption permute these symbols or substitute one symbol for another.
  - In asymmetric-key cryptography, the plaintext and ciphertext are numbers; encryption and decryption are mathematical functions that are applied to numbers to create other numbers.
- Symmetric-key cryptography is based on sharing secrecy: asymmetric-key cryptography is based on personal secrecy.
- In symmetric-key cryptography, symbols are permuted or substituted: In asymmetric-key cryptography, numbers are manipulated.



# 17.4 OTHER SECURITY SERVICES

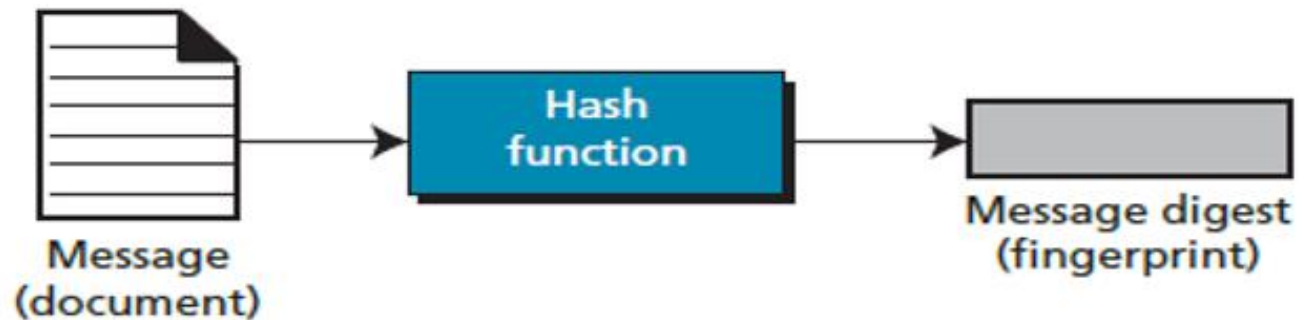
## Message and message digest

- One way to preserve the integrity of a document is through the use of a *fingerprint*.
- The electronic equivalent of the document and fingerprint pair is the message and digest pair.
- To preserve the integrity of a message, the message is passed through an algorithm called a cryptographic hash function. The function creates a compressed image.

---

**Figure 17.8** *Message and digest*

---



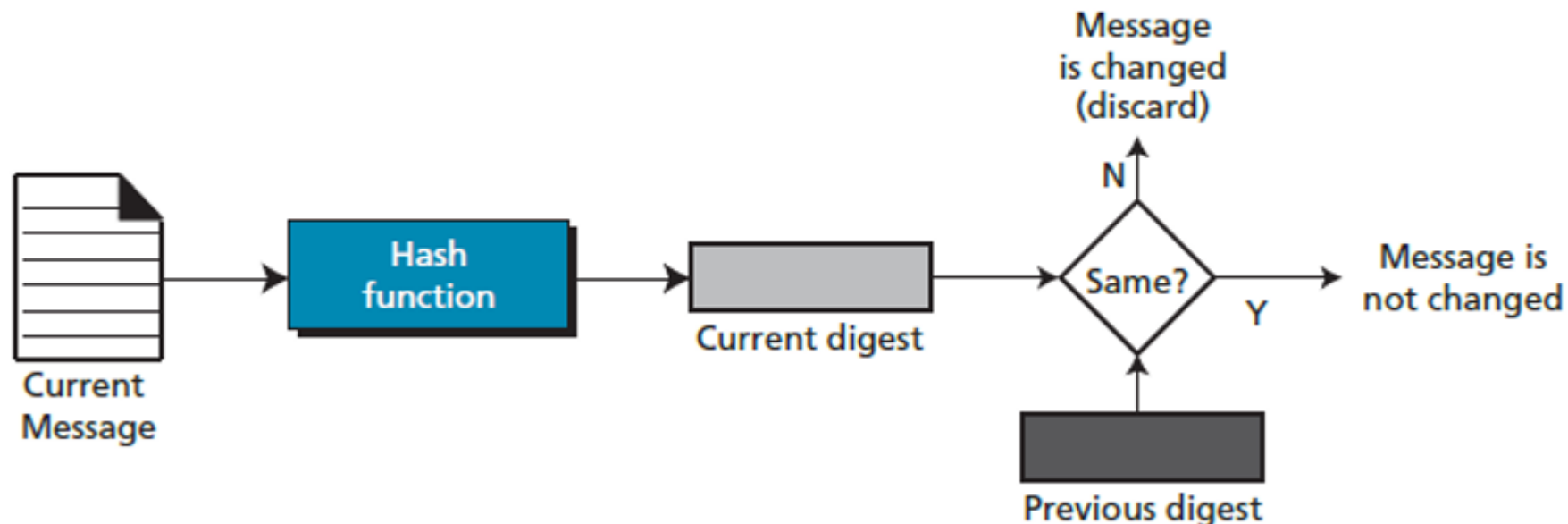
# Hash functions

- A cryptographic hash function takes a message of arbitrary length and creates a message digest of fixed length.
- All cryptographic hash functions need to create a fixed-size digest out of a variable-size message.
- Creating such a function is best accomplished using iteration.
- Instead of using a hash function with variable-size input, a function with fixed-size input is created and is used a necessary number of times.
- The fixed-size input function is referred to as a compression function. It compresses an  $n$ -bit string to create an  $m$ -bit string where  $n$  is normally greater than  $m$ .
- The scheme is referred to as an iterated cryptographic hash function.

## Checking integrity

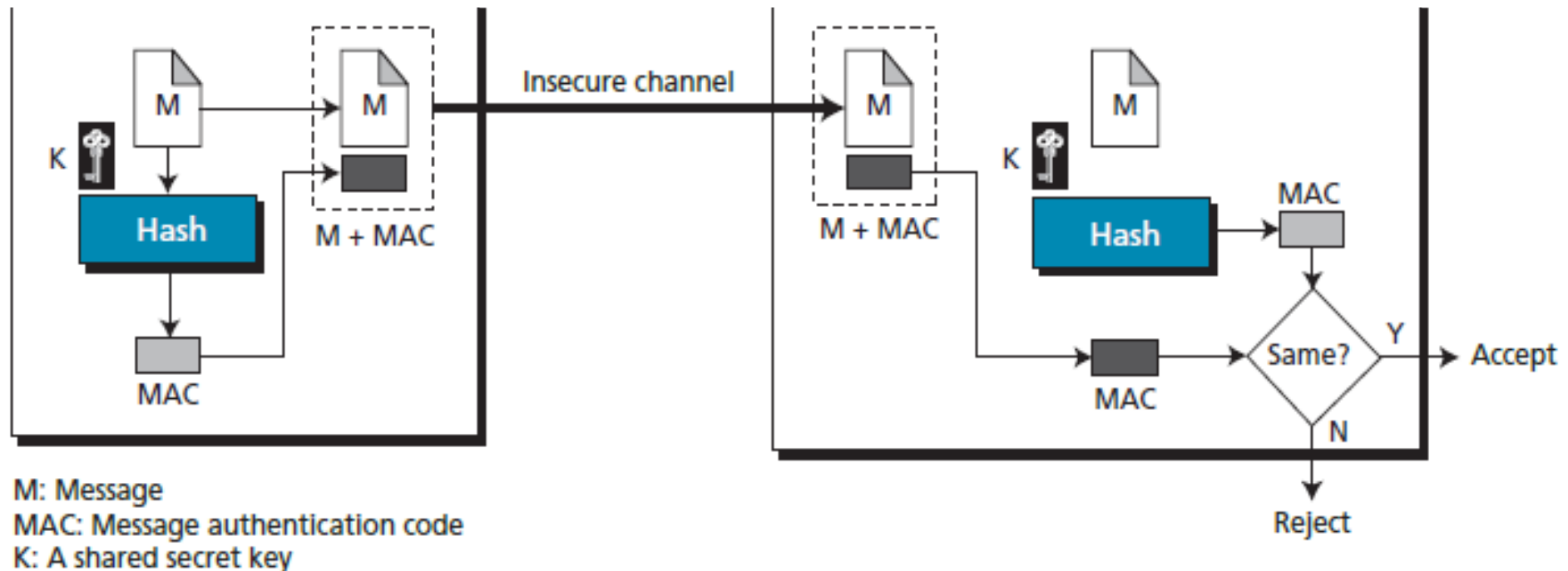
- To check the integrity of a message, we run the cryptographic hash function again and compare the new message digest with the previous one. If both are the same, we are sure that the original message has not been changed.
- Figure 17.9 shows the idea.

Figure 17.9 *Checking integrity*



## 17.4.2 Message authentication

- A digest can be used to check the integrity of a message.
- **To ensure the integrity of the message and the data origin authentication**—that Alice is the originator of the message, not somebody else—we need to include a secret shared by Alice and Bob (that Eve does not possess) in the process; we need to create a **message authentication code (MAC)**.



## Message authentication code (MAC)

- Alice uses a hash function to create a **MAC** from the concatenation of the key and the message,  $h(K + M)$ .
- She sends the message and the MAC to Bob over the insecure channel.
- Bob separates the message from the MAC. He then makes a new MAC from the concatenation of the message and the secret key.
- Bob then compares the newly created MAC with the one received. If the two MACs match, the message is authentic and has not been modified by an adversary.

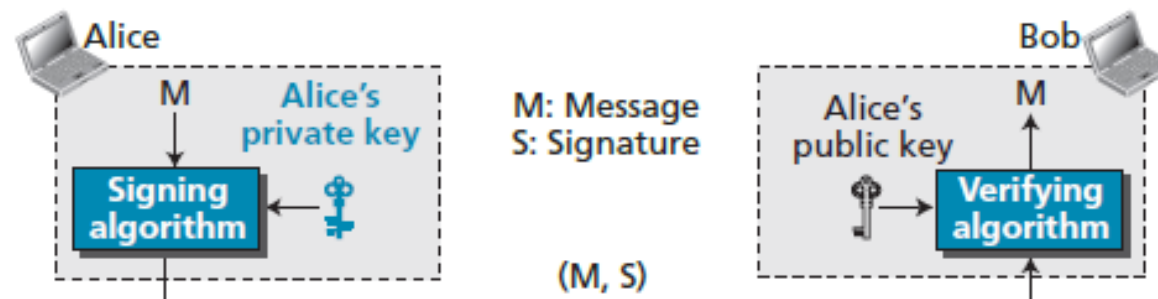
**The National Institute of Standards and Technology (NIST) has issued a standard for a nested MAC that is often referred to as HMAC (hashed MAC).**

## 17.4.3 DIGITAL SIGNATURES

- Another way to provide message integrity and message authentication (and some more security services, as we will see shortly) is a digital signature.
- **A MAC uses a secret key to protect the digest.**
- **A digital signature uses a pair of private–public keys.**

### Process

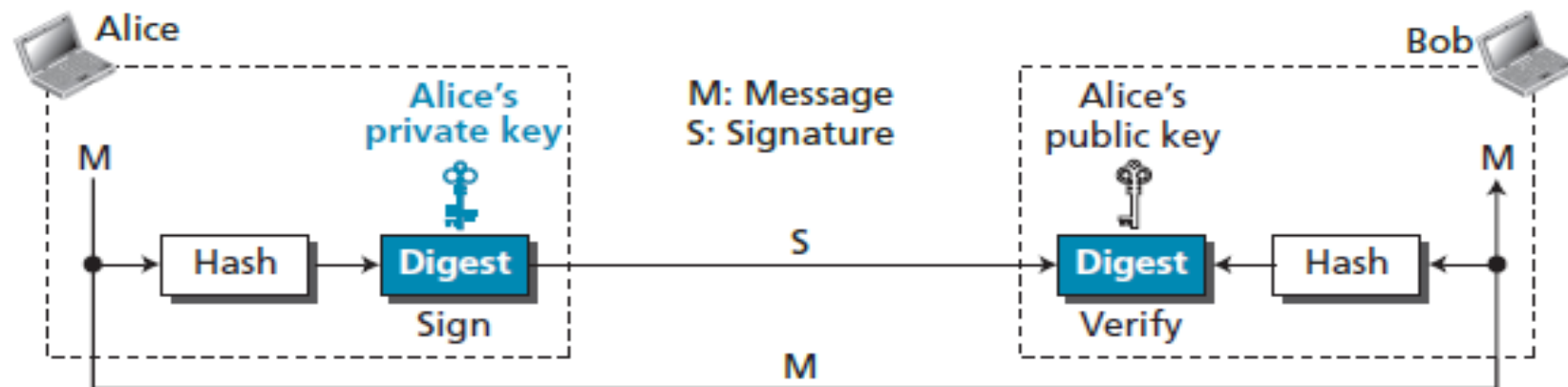
- The sender uses a signing algorithm to sign the message. The message and the signature are sent to the receiver.
- The receiver receives the message and the signature and applies the verifying algorithm to the combination. If the result is true, the message is accepted; otherwise, it is rejected.



# Signing the digest

- In a digital signature system, the messages are normally long, but we have to use asymmetric-key schemes. The solution is to sign a digest of the message, which is much shorter than the message. A carefully selected message digest has a one-to-one relationship with the message. The sender can sign the message digest and the receiver can verify the message digest. The effect is the same.

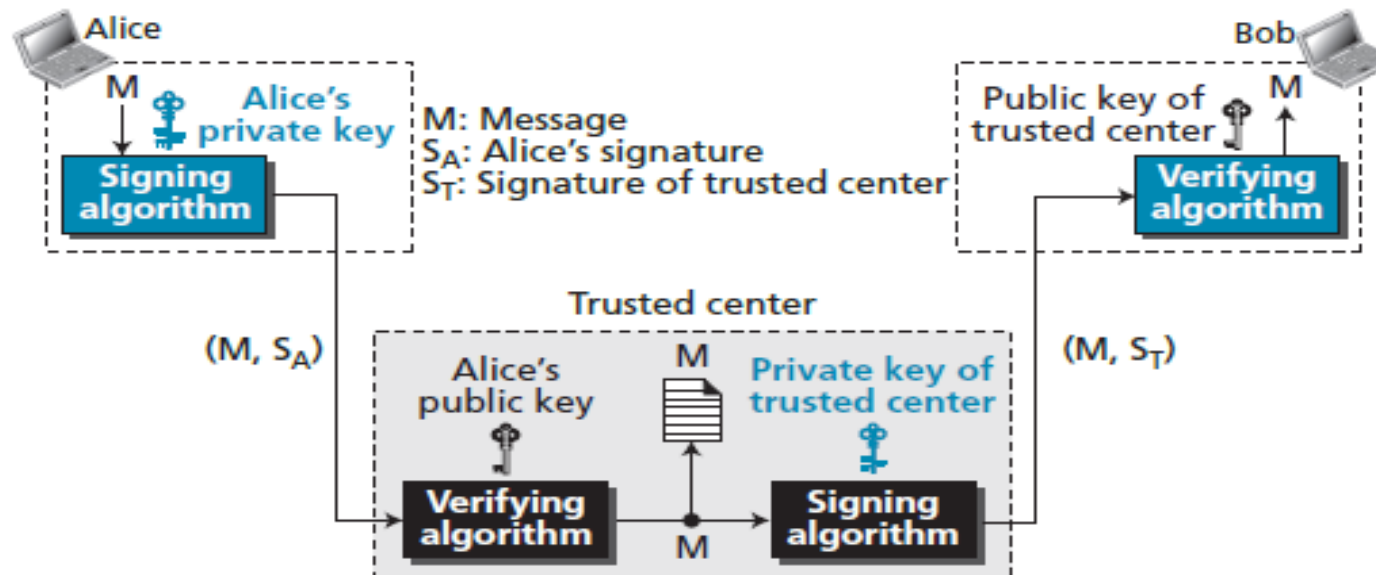
Figure 17.12 *Signing the digest*



# SERVICES

- We discussed several security services including message confidentiality, message authentication, message integrity, and non-repudiation.
- A digital signature can directly provide the last three; for message confidentiality we still need encryption/decryption.

Figure 17.13 Nonrepudiation using digital signatures





## 17.4.4 Entity authentication

- Entity authentication is a technique designed to let one party verify the identity of another party.
- An entity can be a person, a process, a client, or a server.
- The entity whose identity needs to be proven is called the **claimant**.
- The party that tries to verify the identity of the claimant is called the **verifier**.

### Verification categories

- In entity authentication, the claimant must identify him- or herself to the verifier.
- This can be done with one of three kinds of witnesses: something known, something possessed, or something inherent.
  - **Something known**
  - **Something possessed**
  - **Something inherent**

## Passwords

- The simplest and oldest method of entity authentication is the use of a password, which is something that the claimant knows.
- A password is used when a user needs to access a system's resources (login).
- Each user has a user identification that is public, and a password that is private. Passwords, however, are very prone to attack.
- A password can be stolen, intercepted, guessed, and so on.

## Challenge-responses

- In challenge-response authentication, the claimant proves that she knows a secret without sending it to the verifier.

## Biometrics

- Biometrics is the measurement of physical or behavior features that identify a person – that is, authentication by something inherent.
- Biometrics techniques can be divided into two broad categories: physiological and behavior.

## 17.5 KEY MANAGEMENT

- To use symmetric-key cryptography, a shared key needs to be established between the two parties.
- To use asymmetric-key cryptography, each entity needs to create a pair of keys and distribute the public key securely to the community. Key management defines some procedures to create and distribute keys securely.

# Exercises

- P.442 17.7.3 Problems
  - P17-1, P17-6, P17-7, P17-8, P17-9, P17-17